

Diagnostic Brief: CVE-2026-23028

LoongArch KVM Memory Leak
Analysis & Remediation ■

CWE-401: Missing Release of Memory

DIAGNOSTIC PARAMETERS

Vendor:
Linux

Component:
LoongArch KVM

Severity:
Low-Medium

Vulnerability:
Memory Leak (CWE-401)

CIA IMPACT



Confidentiality



Integrity



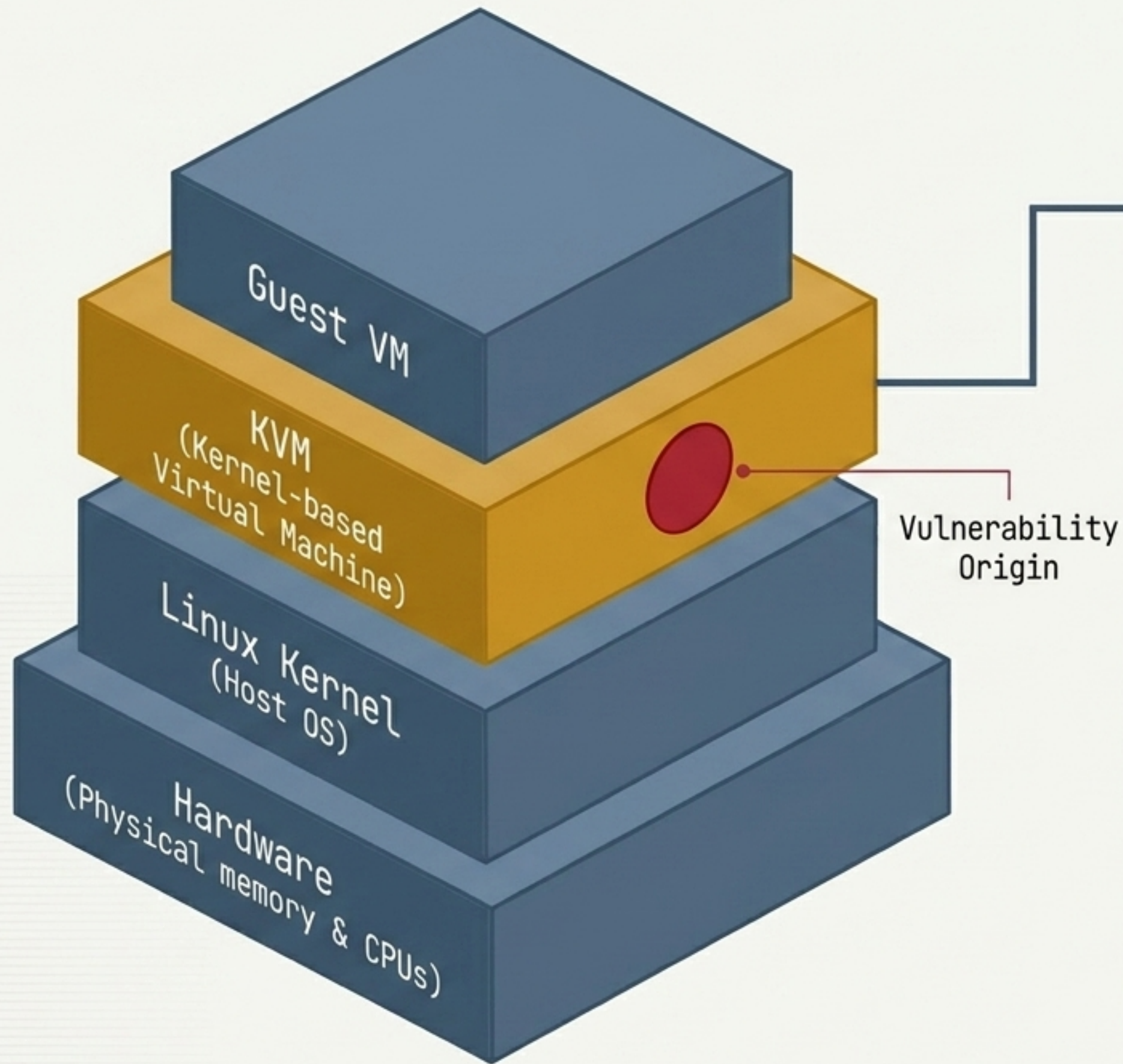
Availability

CORE THREAT SUMMARY



Repeated exploitation leads to memory exhaustion, degraded host performance, and potential availability failure.





Manages Virtual CPUs, Virtual Memory, Virtual Devices, Interrupt Controllers.

KVM enables hardware-level virtualization. Because it operates at the kernel layer, resource mismanagement here cascades to the entire host machine.

Target File: arch/loongarch/kvm/intc/ipi.c | **Target Function:** kvm_ipi_destroy()

EXPECTED BEHAVIOR

```
device->destroy();  
free(device); // Memory properly released
```

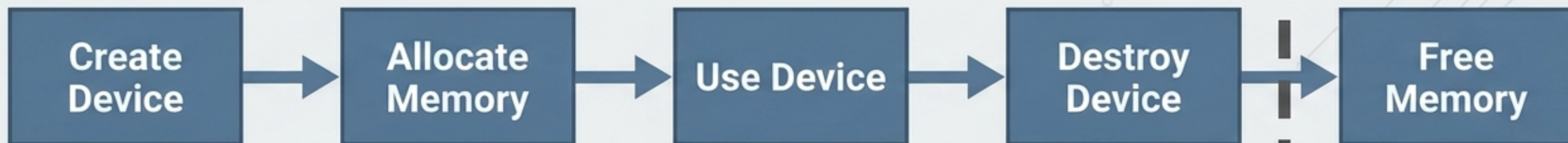
VULNERABLE CODE

```
device->destroy();  
// [ERROR: Missing free() allocation]
```

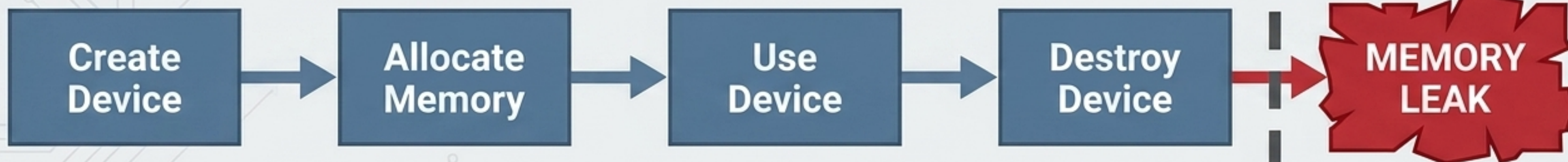


The `kvm_device` structure is destroyed, but the memory allocated for it is never returned to the system.

NORMAL KVM DEVICE LIFECYCLE



VULNERABLE CVE-2026-23028 LIFECYCLE



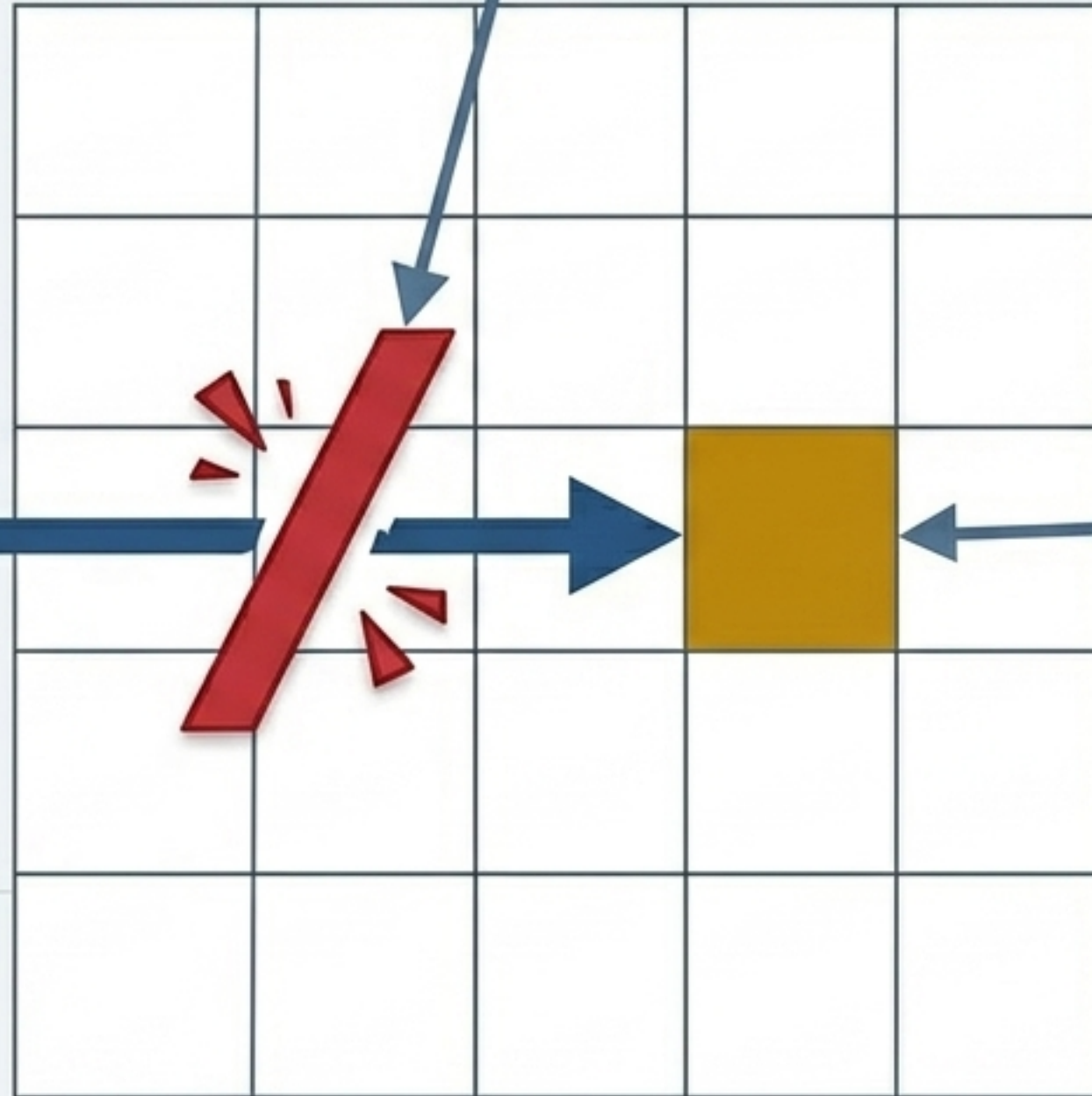
DIVERGENCE POINT →

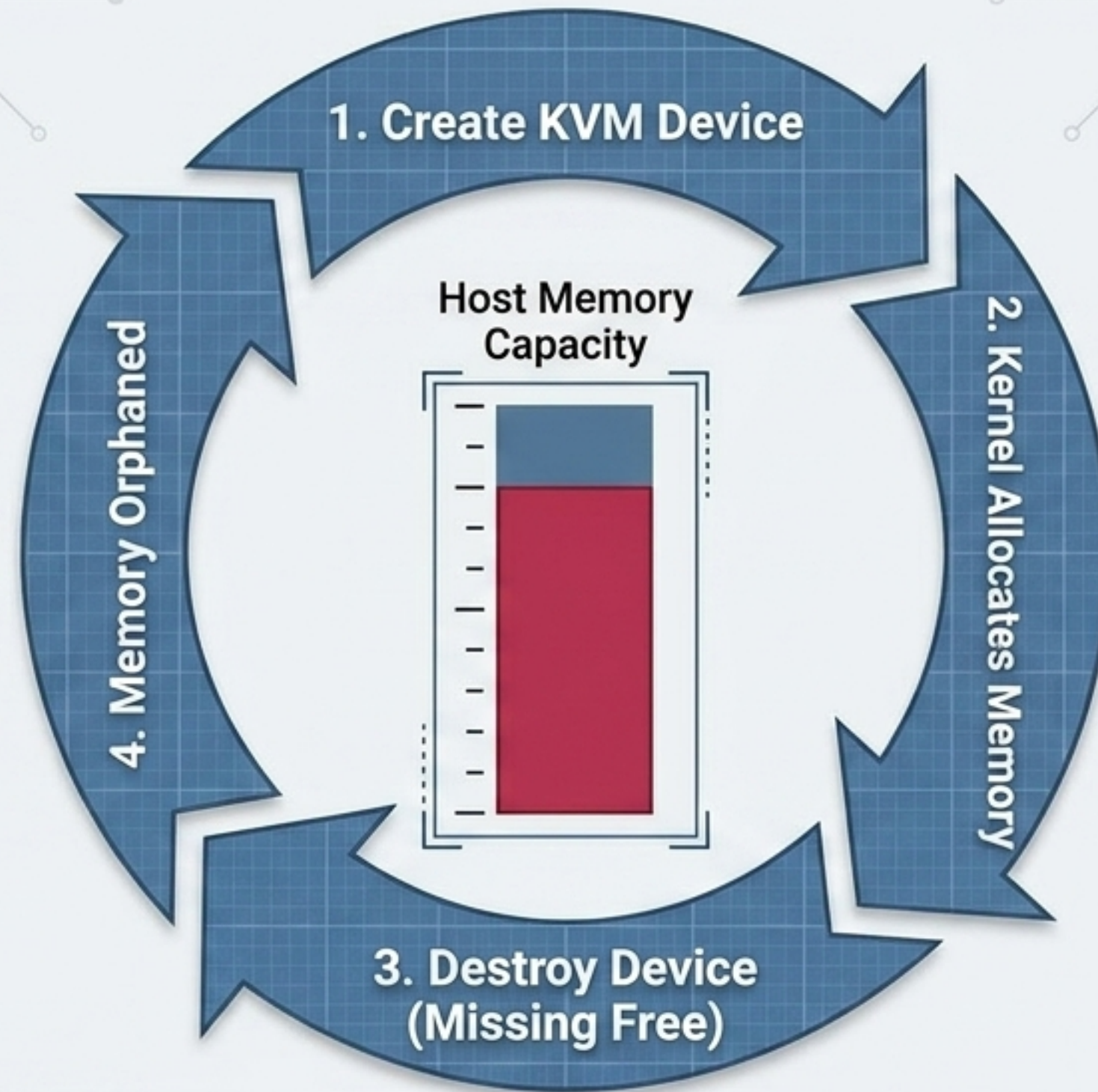
Step 1: Memory Allocated
(e.g., malloc())

Step 2: Pointer Lost / Object Destroyed

Step 3: Orphaned Memory: Memory remains consumed but is inaccessible because free() is never executed.

System Process





THE COMPOUNDING DRAIN

The attacker forces repeated device creation and destruction. Each cycle orphans a microscopic structure. Left unchecked, the loop consumes all available system memory.

THE MACRO IMPACT

Complete Host-Level Denial of Service (DoS) affecting all tenant VMs.

THE ENVIRONMENT

Long-running hypervisor systems that do not reboot frequently.

THE MICRO FLAW

A single unreleased `kvm_device` pointer.

WHY VIRTUALIZATION COMPONENTS MATTER: Because KVM operates at Ring 0 (Kernel), a minor leak bypasses user-space limits. In long-running virtualized environments, tiny persistent leaks compound until the hypervisor starves the host and all hosted virtual machines.

ATTACK PREREQUISITES

WHAT THE ATTACKER NEEDS

- [✓] Local System Access
- [✓] Ability to Interact with KVM subsystems
- [✓] LoongArch Architecture

WHAT THE ATTACKER DOES NOT NEED

- [✗] Remote / Network Access
- [✗] Phishing / User Interaction

Threat Vector is heavily constrained to local, authenticated users on specific hardware architectures.

MITRE ATT&CK MAPPING

THREAT TAG

ID: T1499

Name: Endpoint Denial of Service

Context: The ultimate outcome of the exploitation loop, leading to OS degradation.

THREAT TAG

ID: T1496

Name: Resource Hijacking

Context: The mechanism of tying up kernel-level memory resources maliciously.

Strategic Mapping: Exploitation aligns directly with sustained resource denial and exhaustion tactics.

OPERATIONAL TELEMETRY

```
$ top
```

```
$ htop
```

```
$ free -m
```

```
$ vmstat
```

Alert on unexpected KVM resource growth without corresponding VM provisioning.

Monitor for continuously growing Kernel Memory allocation.

Investigate unexplained
Investigate unexplained host slowdowns or OOM (Out of Memory) kernel panics.

REMEDIATION ROADMAP

**VENDOR FIX
AVAILABLE**

**Upgrade to
Kernel 6.18.7+**

**Upgrade to
Kernel 6.19+**

COMPENSATING SECURITY CONTROLS

Access Control

Restrict unnecessary local KVM access to privileged users only.

Telemetry

Deploy virtualization monitoring tools to baseline normal memory utilization.

Patch Management

Expedite deployment of kernel updates to hypervisor infrastructure.